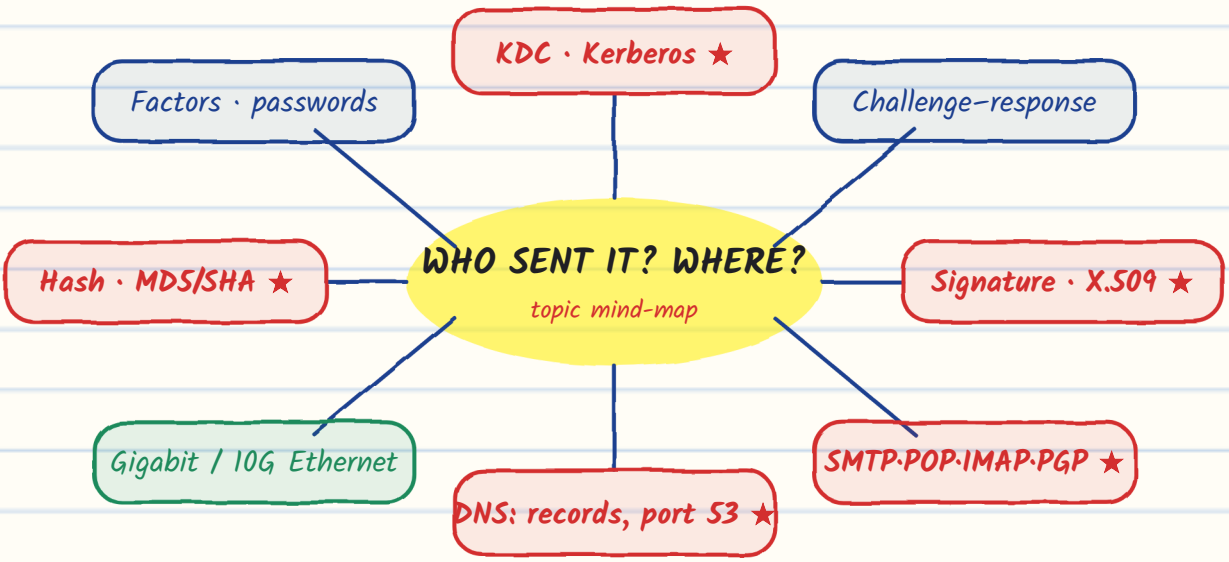
Authentication, DNS & Email

Kerberos · hashes · signatures · X.509 · Gigabit · DNS · mail: exam-ready in 11 sheets



↑ the whole lesson on one page: red = high-yield, blue = concept, green = LAN technology

➜ Syllabus coverage

"Network security: Cryptography, DES, IDEA, public key algorithm; Authentication; Digital signatures; Gigabit Ethernet; Domain Name System: Name servers; Email and its privacy". DES, IDEA, RSA and Diffie–Hellman are in the Transport & Cryptography notes; classic and Fast Ethernet in Data Link & LANs.

High-yield list

① sign private, verify public
② Kerberos: AS, TGS, TGT
③ MD5 128 · SHA-1 160
④ 802.3z · 802.3ab
⑤ DNS 53 · SMTP 25
⑥ POP3 110 · IMAP 143

Legend yellow = key term · red circle = must-memorise fact · **purple box** = memory trick · **red box** = exam trap · **green** = worked example

➜ Contents

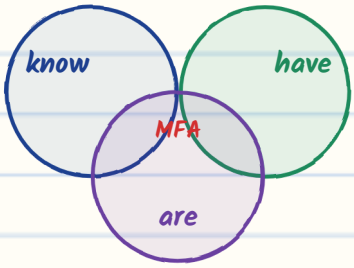
✓ Authentication, challenge–response … p. 2
✓ KDC, Needham–Schroeder, Kerberos … p. 3
✓ Hash functions & MACs ..... p. 4
✓ Digital signatures ..... p. 5
✓ Certificates, PKI, X.509 ..... p. 6
✓ Gigabit & 10 Gigabit Ethernet ..... p. 7
✓ DNS: name servers & records ..... p. 8
✓ Email: SMTP, POP3, IMAP, MIME … p. 9
✓ PGP, S/MIME, night-before … p. 10
✓ Practice MCQs + written ..... p. 11

1 What Authentication Means

MCQ + Written

Definition **Authentication** proves that a user, device or process **is who it claims to be**; **authorization** decides what it may do; **accounting** logs it. Together: **AAA**.

Factor	Examples
Something you **know**	password, PIN, security question
Something you **have**	OTP token, phone (SMS/app), smart card
Something you **are**	fingerprint, iris, face, voice



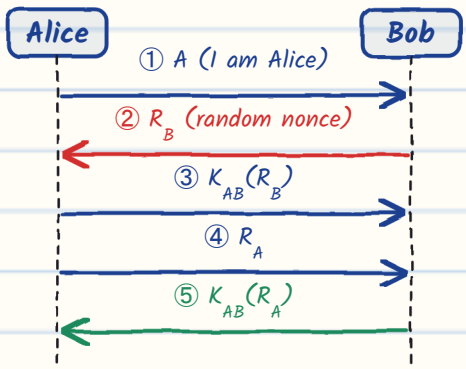
MFA = factors from different circles

Exam trap **Password + PIN is not two-factor**: both are "something you know". MFA needs factors of **different types** (password + OTP from a phone).

2 Passwords & One-Time Passwords

- Store a **salted hash** $H(\text{salt} \| \text{password})$, never the password; a per-user salt defeats **rainbow tables**. Slow hashes (bcrypt, PBKDF2, Argon2) slow down dictionary attacks.
- **OTP**: HOTP (counter) and **TOTP** (a new code every **30 s**); a captured OTP is useless later, so OTPs defeat **replay**.

3 Challenge–Response (Shared Secret Key)



5-message mutual authentication

Bob sends a fresh random **nonce** ("number used once"); only a holder of K_{AB} can return it encrypted.

④–⑤ repeat it the other way: **mutual authentication**. The key **never crosses the network**.

Exam trap: reflection attack The 3-message shortcut lets Trudy open a **second session** and make Bob encrypt his own challenge for her. Fix: the **initiator proves itself first**; separate keys per direction.

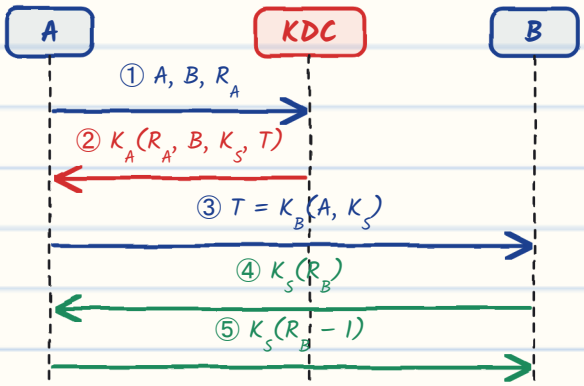
Memory trick "**Fresh question, secret answer**": nonce = no replay, key = proof.

AAA servers **RADIUS** UDP **1812** · **TACACS+** TCP 49 · **EAP/802.1X** Wi-Fi

4 Key Distribution Centre & Needham–Schroeder

high-yield

KDC A trusted server that shares one secret key with **every** user (K_A, K_B …). With N users, N keys are enough instead of $N(N-1)/2$ pairwise keys. The KDC hands out a fresh session key K_S for each conversation.



Needham–Schroeder (1978); T = ticket

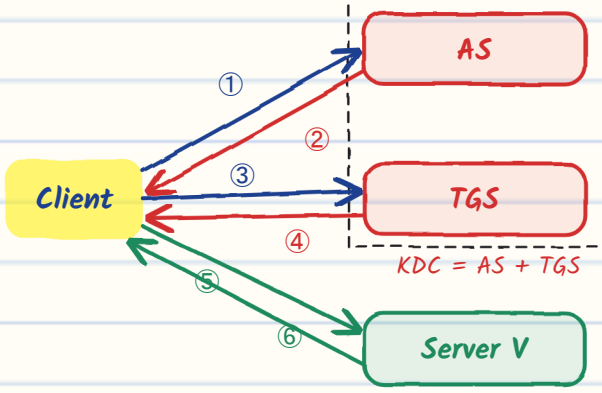
② proves the reply is fresh (it holds R_A) and gives A the **ticket**, which only B can open. ④–⑤ convince each side that the other holds K_S.

Exam trap: the flaw Message ③ has **no freshness**. If an old K_S ever leaks, Trudy can **replay** the old ticket and pose as A (Denning–Sacco, 1981). Fixes: **timestamps** (Kerberos) or the **Otway–Rees** protocol.

5 Kerberos

written favourite

From MIT Project Athena; **v5** (RFC 4120) is the login of Windows Active Directory. Symmetric keys, port 88; **single sign-on**: one password, tickets for every service.



three servers, six messages

1. **C → AS**: user name (no password sent)
2. **AS → C**: $K_C(K_S,$ TGT$)$; K_C is derived from the password, so only the real user can open it
3. **C → TGS**: TGT + K_S(timestamp) + "I want V"
4. **TGS → C**: $K_S(K_{CV})$ + **service ticket** $K_V(C, K_{CV})$
5. **C → V**: service ticket + K_{CV}(timestamp)
6. **V → C**: K_{CV}(timestamp + 1): **mutual authentication**

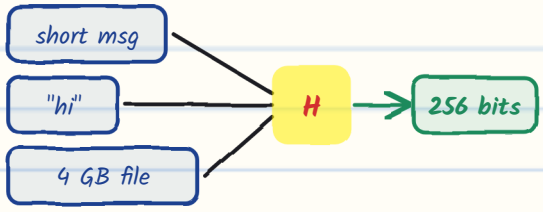
Memory trick **"AS lets you in, TGS gives tickets."** TGT = a cinema wristband; each service ticket = a seat for one film. The wristband (TGT) lasts the day (≈ 10 h).

Exam trap Kerberos needs **synchronised clocks** (default skew ≤ 5 min) because it uses timestamps against replay. The KDC is a **single point of failure**; it does not use public-key cryptography in its basic form.

6 Cryptographic Hash Functions (Message Digests) high-yield

Definition A hash function H maps a message of **any length** to a **fixed-length digest**. It uses **no key**, is fast to compute, and changing one input bit changes about half the output bits (**avalanche effect**).

1. **Pre-image resistance** (one-way): from H(m), finding m is infeasible
2. **Second pre-image resistance**: given m, finding m′ ≠ m with H(m′) = H(m) is infeasible
3. **Collision resistance**: finding any pair m ≠ m′ with equal hashes is infeasible



any length in, fixed length out

Algorithm	Year	Digest	Block	Rounds	Status
MD5 (Rivest)	1991	**128**	512	64	broken (2004): checksums only
SHA-1 (NSA/NIST)	1995	**160**	512	80	broken (2017, SHAttered)
SHA-256 (SHA-2)	2001	**256**	512	64	current standard: TLS, Bitcoin
SHA-512 (SHA-2)	2001	512	1024	80	secure, fast on 64-bit CPUs
SHA-3 (Keccak)	2015	224–512	sponge	24	new design, backup for SHA-2

Sizes in bits. **Birthday attack:** an n-bit digest collides after about $2^{n/2}$ tries → MD5 2^{64}, SHA-1 2^{80}, SHA-256 2^{128}.

7 Message Authentication Code (MAC) & HMAC

MAC tag = C(K, M) from the message **and a shared key**; the receiver recomputes it. Proves **integrity + origin**: without K no valid tag.

HMAC (RFC 2104) $H((K \oplus opad) \| H((K \oplus ipad) \| M))$
ipad = 0x36..., opad = 0x5C... · HMAC-SHA256 in TLS, IPsec

Tool	Key	Integrity	Auth.	Non-repud.	Secrecy
Hash alone	none	errors only	✗	✗	✗
MAC / HMAC	shared secret	✓	✓	✗	✗
Digital signature	private / public	✓	✓	✓	✗
Encryption	any	✗	✗	✗	✓

Memory trick SHA-**1** ↔ **160**; MD5 is smaller (128). In SHA-2 the name **is** the length: SHA-256 → 256.

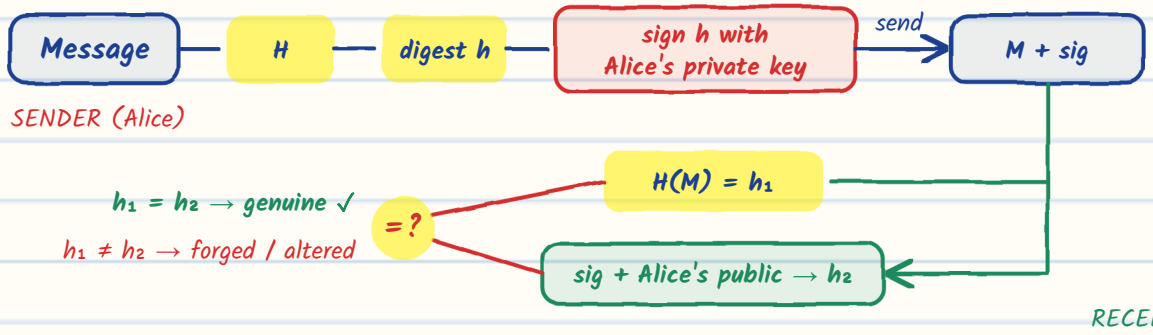
Exam trap A MAC gives **no non-repudiation**: Bob knows K too, so he could have made the tag. A hash is **not encryption**: no key, no reversing.

8 Digital Signatures

high-yield

Definition A digital signature is a value computed from a message with the **signer's private key** that anyone can check with the **signer's public key**. It gives *authentication*, *integrity* and *non-repudiation*, but **not confidentiality**.

Requirements: ① the receiver can verify the sender's identity; ② the sender cannot deny it later; ③ the receiver cannot forge or alter it.



hash-then-sign: the receiver recomputes the hash and checks it against the signature

→ Why sign the hash?

- Public-key operations are slow; a 256-bit digest is tiny
- The signature size stays fixed whatever the message length
- The message can stay readable (plain text + signature)

Algorithm	Based on
RSA	factoring; most widely used
DSA (DSS, FIPS 186, 1994)	discrete log; NIST, signing only
ECDSA, EdDSA	elliptic curves: smaller keys

Worked example: RSA signature ✍️ Keys $n = 33$, $e = 3$ (public), $d = 7$ (private), since $3 \times 7 = 21 \equiv 1 \pmod{\varphi = 20}$. Digest $h = 4$.

1. Sign: $s = h^d \bmod n = 4^7 \bmod 33 = 16384 \bmod 33 =$ **16** $33 \times 496 = 16368$
2. Verify: $s^e \bmod n = 16^3 \bmod 33 = 4096 \bmod 33 = 4 = h$ ✓ $33 \times 124 = 4092$

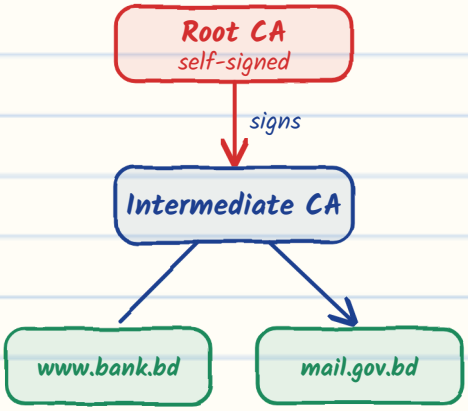
Exam trap **Sign** with the **sender's private** key, verify with the **sender's public** key. **Encrypt** for secrecy with the **receiver's public** key. For both: sign first, then encrypt.

Memory trick **"Private signs, public checks."** Only you hold your pen (private key); everyone can compare it with your specimen signature (public key).

Without public keys a trusted arbiter ("Big Brother", BB) signs for users who share keys with it, keeping $K_{BB}(A, t, P)$ as proof. Uses: code signing, TLS certificates, S/MIME, PGP, blockchain.

9 Why Certificates? MCQ + Written

The problem A public key on its own says nothing about its owner. Trudy can publish her key under Bob's name (**man-in-the-middle**). A **certificate** is a document that binds a **name to a public key**, digitally signed by a trusted **Certification Authority (CA)**.



chain of trust up to a trusted root

PKI = CAs + **RA**s (check identity) + certificates + directories + revocation. The root CA's certificate is **self-signed** and pre-installed in browsers and OSs. **Revocation** (stolen key): a **CRL** (revocation list) or a live **OCSP** check.

PGP uses a **web of trust** instead: users sign each other's keys.

Bangladesh link **ICT Act 2006**: digital signatures are legal; the **CCA** (Controller of Certifying Authorities) licenses CAs.

10 X.509 Certificate Format high-yield

ITU-T standard (v1 1988), used by TLS/HTTPS, S/MIME, IPsec and code signing. Current **version 3** (1996) added **extensions**. Encoded in ASN.1 (DER); files .cer, .crt, .pem.

Field	Meaning
Version · serial no.	v1/2/3 · unique per CA
Signature algorithm	e.g. SHA-256 with RSA
Issuer	the CA's X.500 name
Validity	not before / not after
Subject	owner (CN = www.bank.bd)
Subject public key	the certified key
Extensions (v3)	key usage, alt. names
CA's signature	over all fields above

How a browser checks www.bank.bd

1. Server sends its certificate + the intermediate's
2. Check its signature with the intermediate CA's public key, then the intermediate with the root
3. Check dates, name match, not revoked
4. Then trust the subject's public key

Memory trick Certificate = **passport**: subject = holder, key = photo, issuer = government, CA signature = stamp.

Exam trap It holds the subject's **public** key only, and is signed with the **CA's** private key.

11 Gigabit Ethernet (1000 Mbps) high-yield

Definition Ethernet at **1 Gbps** (10 × Fast Ethernet) with the **same frame format** (64–1518 bytes), so it works with older Ethernet. Standards: **802.3z** (1998, fibre + short copper) and **802.3ab** (1999, 1000BASE-T).

Name	Standard	Medium	Max length	Coding
1000BASE-SX	802.3z	multimode fibre, 850 nm	220–550 m	8B/10B
1000BASE-LX	802.3z	single-mode fibre, 1310 nm	**5 km**	8B/10B
1000BASE-CX	802.3z	shielded twinax copper	25 m	8B/10B
1000BASE-T	802.3ab	Cat 5e UTP, **all 4 pairs**	**100 m**	PAM-5

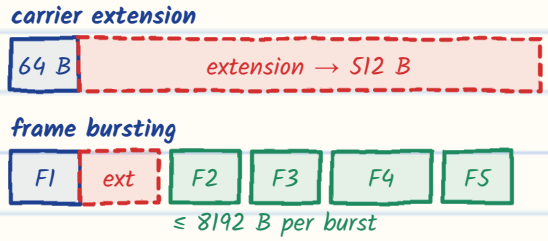
8B/10B → line rate **1.25 Gbaud**. 1000BASE-T: 4 pairs × 250 Mbps, each pair both ways (echo cancellation). LX also runs 550 m on multimode.

→ Half duplex: carrier extension & frame bursting

At 1 Gbps a 64-byte frame lasts 0.512 µs, so CSMA/CD would limit the network to about **25 m**. Two fixes, **half-duplex only**:

Carrier extension pad every short frame so it fills at least **512 bytes** (4096 bit times) → about **200 m**. Cost: a 64-byte frame is only 1/8 useful.

Frame bursting after one extended frame, send **several short frames back to back** without releasing the line, up to 8192 bytes.



Exam trap Real Gigabit links are **full duplex** through switches: no collisions, no extension. The minimum frame stays 64 bytes; only the minimum slot grows to 512 bytes.

12 10 Gigabit Ethernet and Beyond

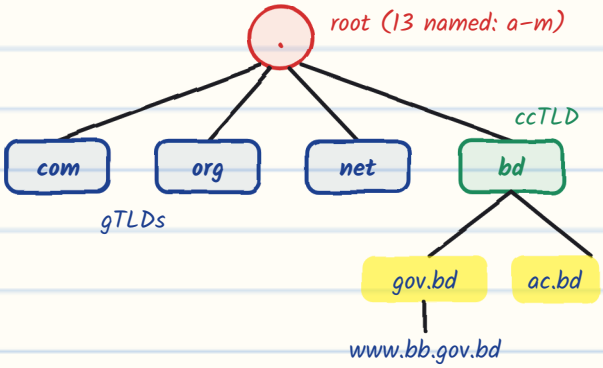
Name	Standard	Reach
10GBASE-SR/LR/ER	802.3ae (2002)	fibre 300 m/10/40 km
10GBASE-T	802.3an (2006)	Cat 6a · 100 m
40G / 100G	802.3ba (2010)	data centres

10G is **full duplex only**: no CSMA/CD. Fibre uses **64B/66B** coding.

Memory trick "**z = glass, ab = copper.**" S = short λ (850 nm), L = long (1310 nm).

13 Domain Name System (DNS) high-yield

Definition A hierarchical, distributed database mapping names to IP addresses, mail servers and aliases (Mockapetris; RFC 1034/1035, 1987). **Port 53**: **UDP** for queries, **TCP** for zone transfers and replies over 512 bytes.



the name tree, read right to left: www . bb . gov . bd .

Zone = the part of the tree one organisation runs: a **primary** server plus **secondaries** that copy it by zone transfer (AXFR, TCP). Label ≤ **63** chars, name ≤ **255** bytes.

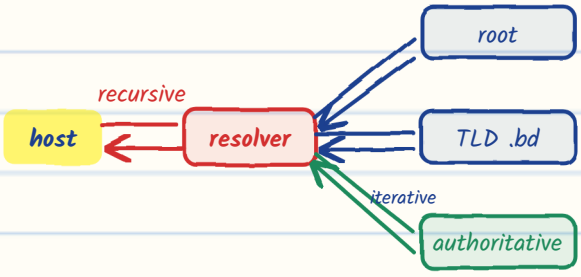
Server	Job
Root	refers to TLD servers
TLD	refers to the domain
Authoritative	final answer
Local resolver	asks, caches (TTL)

➜ Resource records: (name, TTL, class, type, value)

Type	Value	Example
A	IPv4 address (32 bit)	www 3600 IN A 203.0.113.10
AAAA	IPv6 address (128 bit)	www … IN AAAA 2001:db8::10
MX	mail server + priority (low = first)	IN MX 10 mail.bb.gov.bd.
CNAME	alias → canonical name	ftp IN CNAME www
NS	a name server for the zone	IN NS ns1.bb.gov.bd.
PTR	IP → name (reverse)	10.113.0.203.in-addr.arpa
SOA	zone data: serial, refresh, expire	one per zone, first

➜ Recursive vs iterative resolution

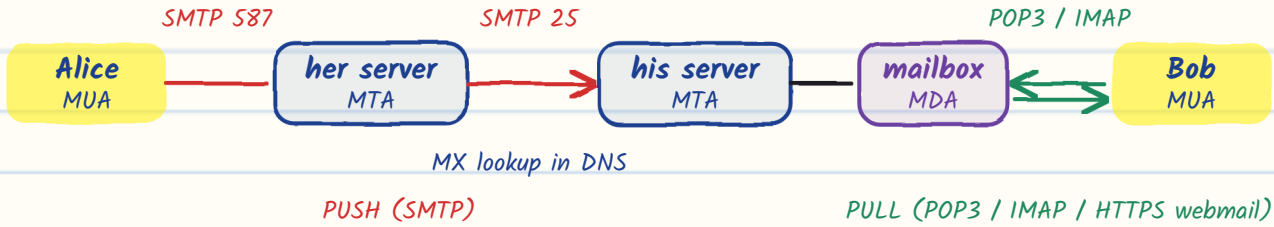
Recursive: the server does the whole job and returns the final answer (host → resolver). Iterative: the server returns a **referral** and the asker continues (resolver → root → TLD → authoritative). Caching by TTL means most lookups never reach the root.



Memory trick "**Quad-A = four times the A**": AAAA holds 128 bits, four times A's 32. **MX = Mail eXchange**; **PTR = poin-T-er back**.

Exam trap DNS is **not** UDP-only: TCP 53 for zone transfers. **Cache poisoning** plants false records; **DNSSEC** signs records (integrity), it does not encrypt them.

14 How Email Travels high-yield



MUA = user agent (Outlook) · MTA = transfer agent (Postfix, Sendmail) · MDA = delivery agent

Protocol	Port (TLS)	Job	Key points
SMTP	25 · 587 · (465)	send / relay, push	25 relay, 587 submission
POP3	110 · (995)	download to one device	usually deletes from server
IMAP4	143 · (993)	mail stays on server	folders, sync on all devices

S: 220 mail.bb.gov.bd ESMTP
C: EHLO pc.example.org S: 250
C: MAIL FROM:<alice@example.org>
C: RCPT TO:<bob@bb.gov.bd>
C: DATA S: 354 end with "."
C: Subject: Hi ... . S: 250
C: QUIT S: 221 bye

SMTP replies: 2xx OK, 3xx send more, 4xx temporary, 5xx permanent error. **POP3:** USER, PASS, LIST, RETR, DELE, QUIT.

Exam trap SMTP **sends**; POP3/IMAP **retrieve**. Webmail uses **HTTPS** to the browser, but SMTP still moves mail between servers.

15 MIME: Beyond 7-bit ASCII

RFC 822 mail was **7-bit ASCII** only. MIME (RFC 2045–2049) adds headers for Bangla (UTF-8), images, PDFs and multi-part mail:

- **MIME-Version**: 1.0
- **Content-Type**: text/plain, image/jpeg, application/pdf, **multipart/mixed**
- **Content-Transfer-Encoding**: 7bit, 8bit, **base64**, quoted-printable

Worked example: base64 ✍ "Man" = 77, 97, 110 = 01001101 01100001 01101110
6-bit groups: 010011 · 010110 · 000101 · 101110 = 19, 22, 5, 46 → TWFu
3 bytes → 4 characters: a 3 MB attachment grows to about **4 MB** (+33%).

Memory trick Ports in order of the mail's journey: **25** → **110** → **143** (send, pop it down, keep it on the server). TLS twins: **465, 995, 993**.

Anti-spoofing (DNS TXT records) **SPF** lists the servers allowed to send for a domain · **DKIM** signs headers with a key published in DNS · **DMARC** says what to do when they fail.

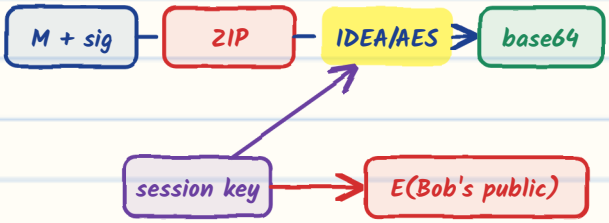
16 Email Privacy: PGP & S/MIME

high-yield

Threats: **eavesdropping**, **tampering**, **spoofing** (forged From:). TLS/STARTTLS protects each hop only; end-to-end privacy needs PGP or S/MIME.

PGP (Phil Zimmermann, 1991; OpenPGP RFC 4880). Originally **IDEA** (128-bit) for the text, **RSA** for keys, **MD5** digest; today AES, SHA-256, RSA/ECC.

1. **Sign** the digest with Alice's private key
2. **Compress** (ZIP)
3. **Encrypt** with a one-time session key, which goes encrypted with Bob's public key
4. **Radix-64** (base64) for SMTP



fast cipher for the bulk, public key only for the short session key

PGP is hybrid: symmetric + public key

	PGP / OpenPGP	S/MIME
Trust model	**web of trust** (users sign keys)	**X.509 certificates** from a CA hierarchy
Typical use	individuals, open-source software	organisations, Outlook, government

Night-before fact sheet

MFA = factors of different types
Needham–Schroeder flaw: old-key replay
MD5 128 · SHA-1 160 · SHA-256 256 bits
MAC: no non-repudiation; signature: yes
X.509 v3: issuer, subject, public key, CA sig
802.3z fibre · 802.3ab 1000BASE-T 100 m
10G: 802.3ae, full duplex only
A · AAAA · MX · CNAME · NS · PTR · SOA
MIME: Content-Type, base64 (+33%)

KDC: N keys, not $N(N-1)/2$
Kerberos: AS → TGT, TGS → ticket, port 88
Birthday attack $\approx 2^{n/2}$
Sign: sender private · verify: sender public
Revocation: CRL / OCSP
Carrier extension: slot 512 B · burst 8192 B
DNS 53: UDP query · TCP zone transfer
SMTP 25/587 · POP3 110 · IMAP 143
PGP: sign → ZIP → encrypt → radix-64

Top traps password + PIN ≠ MFA · a hash has no key · MAC ≠ non-repudiation · certificates hold the public key only · Gigabit min frame still 64 B · DNS uses TCP too · POP3/IMAP never send · TLS ≠ end-to-end

All tricks together Fresh question, secret answer · AS lets you in, TGS gives tickets · SHA-1 ↔ 160 · private signs, public checks · certificate = passport · z = glass, ab = copper · quad-A = 4 × A · 25 → 110 → 143

Also practise (written): ① sign and verify with RSA, $n = 33$ · ② Needham–Schroeder and its flaw · ③ recursive vs iterative DNS (diagram) · ④ how PGP gives secrecy + authentication

✓ Practice MCQs (exam pattern, 10 marks)

try first, then check

1. A digital signature is verified with the:
   (a) receiver's private key (b) sender's public key
   (c) sender's private key (d) shared DES key

2. The digest length of SHA-1 is:
   (a) 128 bits (b) 256 bits
   (c) 160 bits (d) 512 bits

3. DNS record for an IPv6 address:
   (a) A (b) MX
   (c) PTR (d) AAAA

4. The Kerberos TGT is issued by the:
   (a) AS (b) TGS
   (c) file server (d) CA

5. 1000BASE-T (Cat 5e UTP) is defined in:
   (a) 802.3u (b) 802.3z
   (c) 802.3ab (d) 802.3ae

6. Which service does a MAC NOT give?
   (a) non-repudiation (b) integrity
   (c) origin check (d) tamper detection

7. Default IMAP port (no TLS):
   (a) 110 (b) 143
   (c) 25 (d) 993

8. Carrier extension makes the minimum slot:
   (a) 64 bytes (b) 1518 bytes
   (c) 8192 bytes (d) 512 bytes

9. An X.509 certificate is signed with the:
   (a) CA's private key (b) owner's private key
   (c) CA's public key (d) owner's public key

10. DNS uses TCP port 53 mainly for:
    (a) A-record queries (b) reverse lookups
    (c) zone transfers (d) root hints

Answer key → 1-b · 2-c · 3-d · 4-a · 5-c · 6-a · 7-b · 8-d · 9-a · 10-c

Written question Explain with a diagram how Kerberos authenticates a client to a server. How does it give mutual authentication, and why does it need synchronised clocks? 8 marks

1. AS + TGS = the KDC, which shares a secret key with every user and server; diagram as on sheet 3 (1)
2. C → AS: user name. AS → C: $K_C(K_S, TGT)$; K_C comes from the password, which never crosses the network (2)
3. C → TGS: TGT + K_S(timestamp) + server name. TGS → C: $K_S(K_{CV})$ + ticket $K_V(C, K_{CV})$ (2)
4. C → V: ticket + K_{CV}(timestamp); V → C: K_{CV}(timestamp + 1). Only the real V can open the ticket: mutual authentication (2)
5. Timestamps stop replay, so clocks must agree within ≈ 5 min (1)

→ Before the exam ✓

- ✓ Draw challenge–response, spot reflection
- ✓ Write the 6 Kerberos messages
- ✓ Hash sizes, MAC vs signature, X.509
- ✓ Gigabit media, DNS records, mail ports